

Information Security



Attacks, Services and Mechanisms

- **Security Attack:** Any action that compromises the security of information.
- **Security Mechanism:** A mechanism that is designed to detect, prevent, or recover from a security attack.
- **Security Service:** A service that enhances the security of data processing systems and information transfers. A security service makes use of one or more security mechanisms.

Security Threats

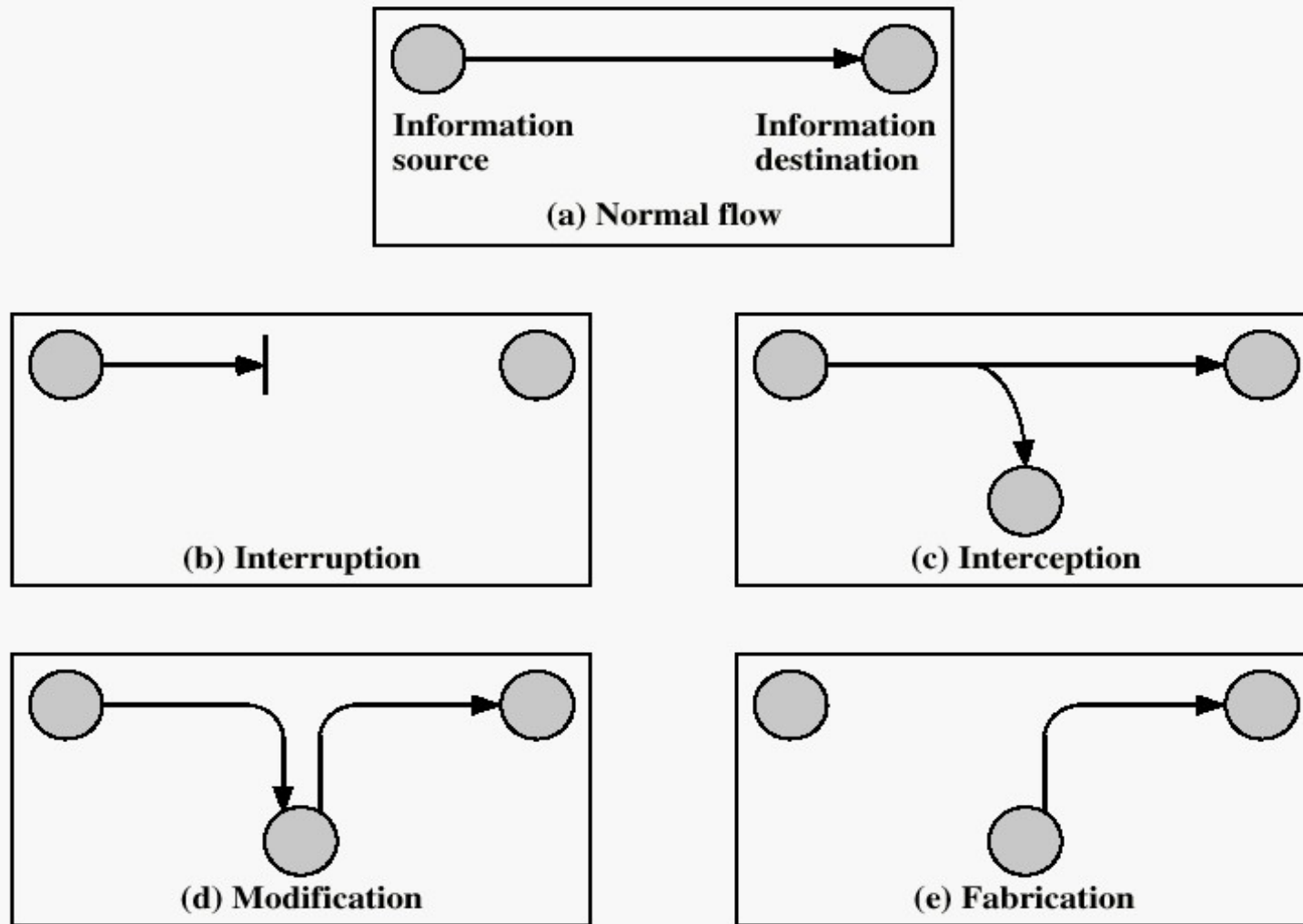
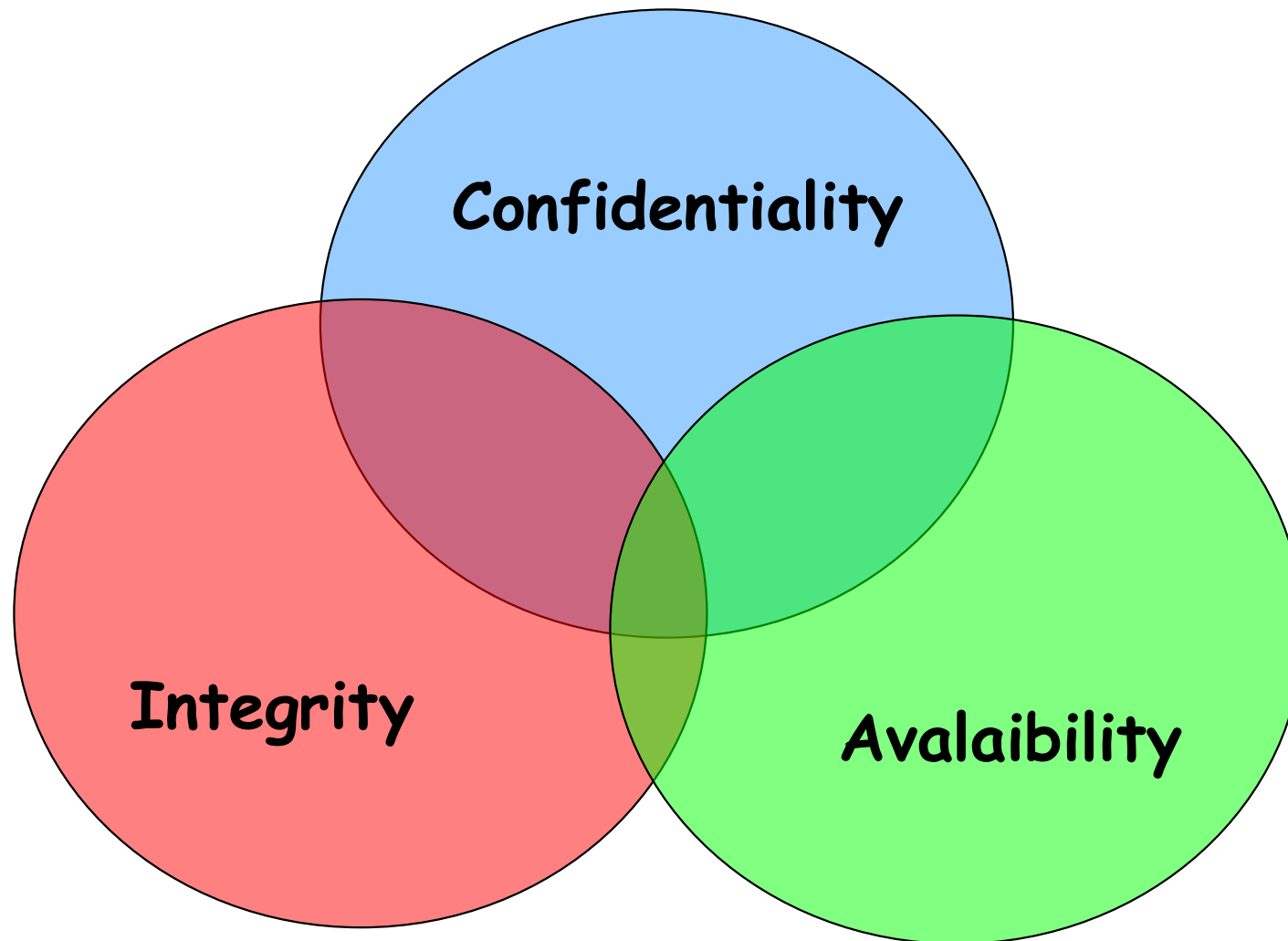


Figure 1.1 Security Threats

Security Threats

- **Interruption:** This is an attack on availability
- **Interception:** This is an attack on confidentiality
- **Modification:** This is an attack on integrity
- **Fabrication:** This is an attack on authenticity

Security Goals



Security Attacks

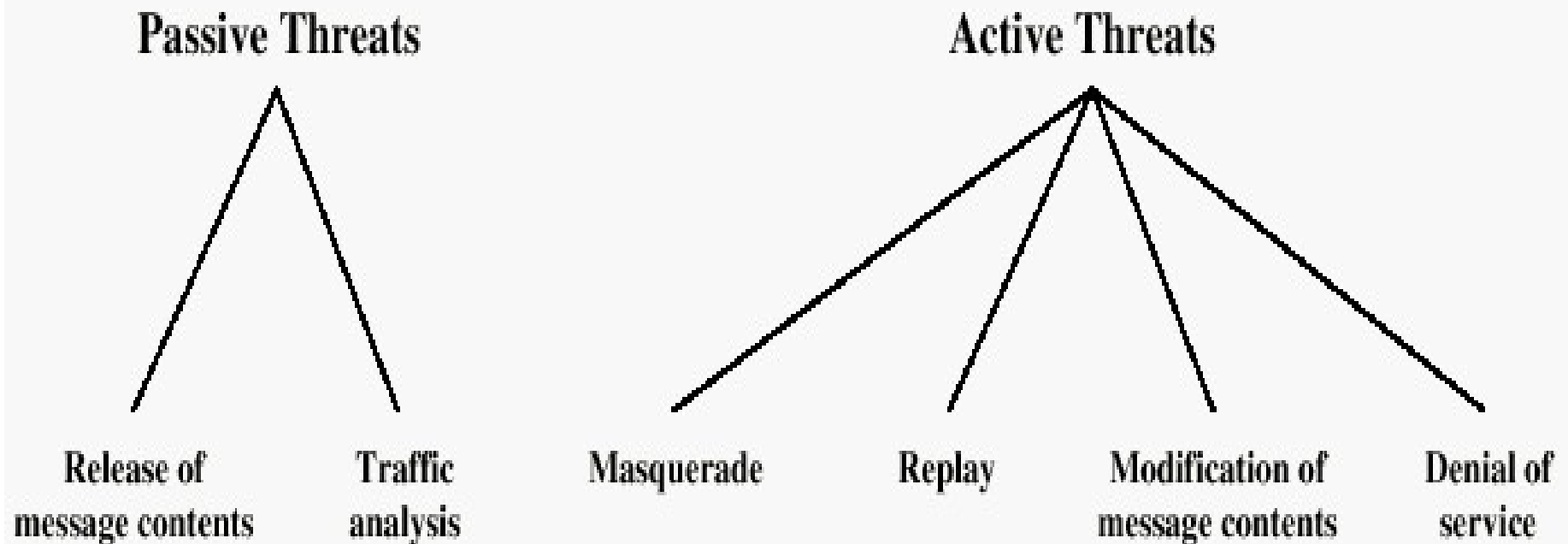


Figure 1.2 Active and Passive Security Threats

Security Services

- A. Confidentiality (privacy)
- B. Authentication (who created or sent the data)
- C. Integrity (has not been altered)
- D. Non-repudiation (the order is final)
- E. Access control (prevent misuse of resources)
- F. Availability (permanence, non-erasure)
 - Denial of Service Attacks
 - Virus that deletes files

A. Data confidentiality

These services provide for the protection of data from unauthorized disclosure as described below

- a) **Connection confidentiality** - provides for the confidentiality of all user-data on a connection
- b) ***Connectionless confidentiality*** - provides for the confidentiality of all user-data in a single data block.
- c) **Selective field confidentiality** - provides for the confidentiality of selected fields within the user-data on a connection or in a single data block.
- d) **Traffic flow confidentiality** This service provides for the protection of the information which might be derived from observation of traffic flows.

B. Authentication

The Assurance that the communicating entity is the one that it claims it to be.

- a) **Peer entity authentication** This service, when provided by the (N)-layer, provides validation to the (N - 1)-entity that the peer entity is the claimed (N)-entity.
- b) **Data origin authentication** This service, when provided by the (N)-layer, provides corroboration to an (N + 1)-entity that the source of the data is the claimed peer (N + 1)-entity.

C. Integrity

Assurance that data received are exactly as sent by an unauthorized entity (i.e. contain no modification, insertion, deletion or replay).

a) Connection integrity with recovery

- provides for the integrity of all user-data on a connection
- detects any modification, insertion, deletion or replay of any data within an entire data sequence (with recovery attempted).

b) Connection integrity without recovery

- the previous one but with no recovery attempted.

c) Selective field connection integrity –

- provides for the integrity of selected fields within the user data of data block transferred over a connection and determine whether the selected fields have been modified, inserted, deleted or replayed.

C. Integrity (contd..)

d) Connectionless integrity

- provides for the integrity of a single data block
- determine whether a received data block has been modified.
- Additionally, a limited form of detection of replay may be provided.

e) Selective field connectionless integrity

provides for the integrity of selected fields within a single connectionless data block

determine whether the selected fields have been modified.

D. Non-repudiation

- Provides protection against denial by one of the entities involved in a communication of having participated in all or part of the communication.

a) **Non-repudiation , Origin**

- Proof that the message was sent by the specified party -
 - This will protect against any attempt by the sender to falsely deny sending the data or its contents.

b) **Non-repudiation, Destination**

- Proof that the message was message was received by the specified party
 - This will protect against any subsequent attempt by the recipient to falsely deny receiving the data or its contents.

E. *Access control*

Provides protection against unauthorized use of resources accessible

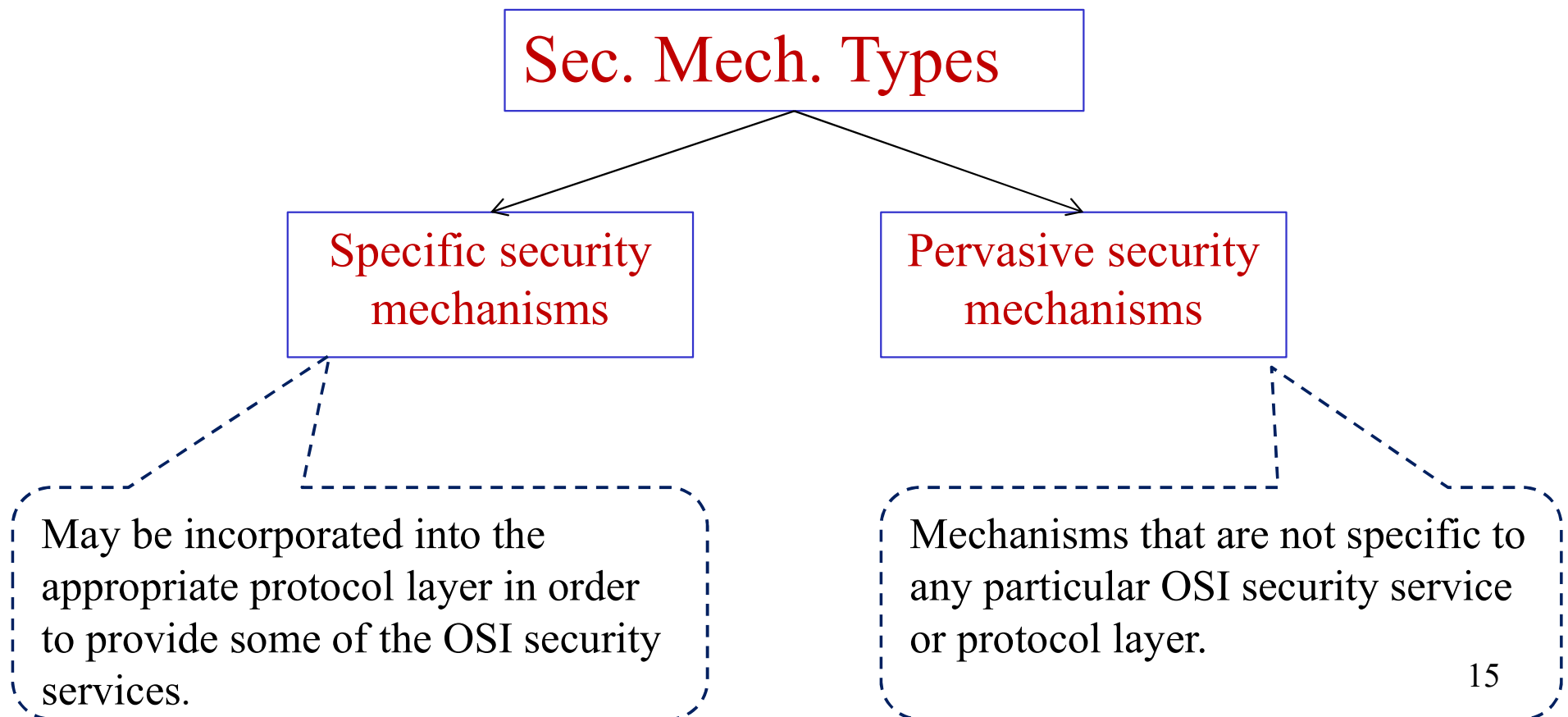
Example: the service controls who can have access to a resource, under what circumstances, and what those accessing the resource are allowed to do.

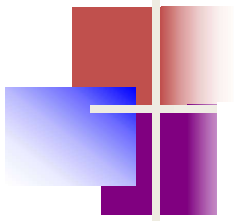
F. Availability

- The property of a system or a system resource being accessible and usable upon demand by an authorized system entity.

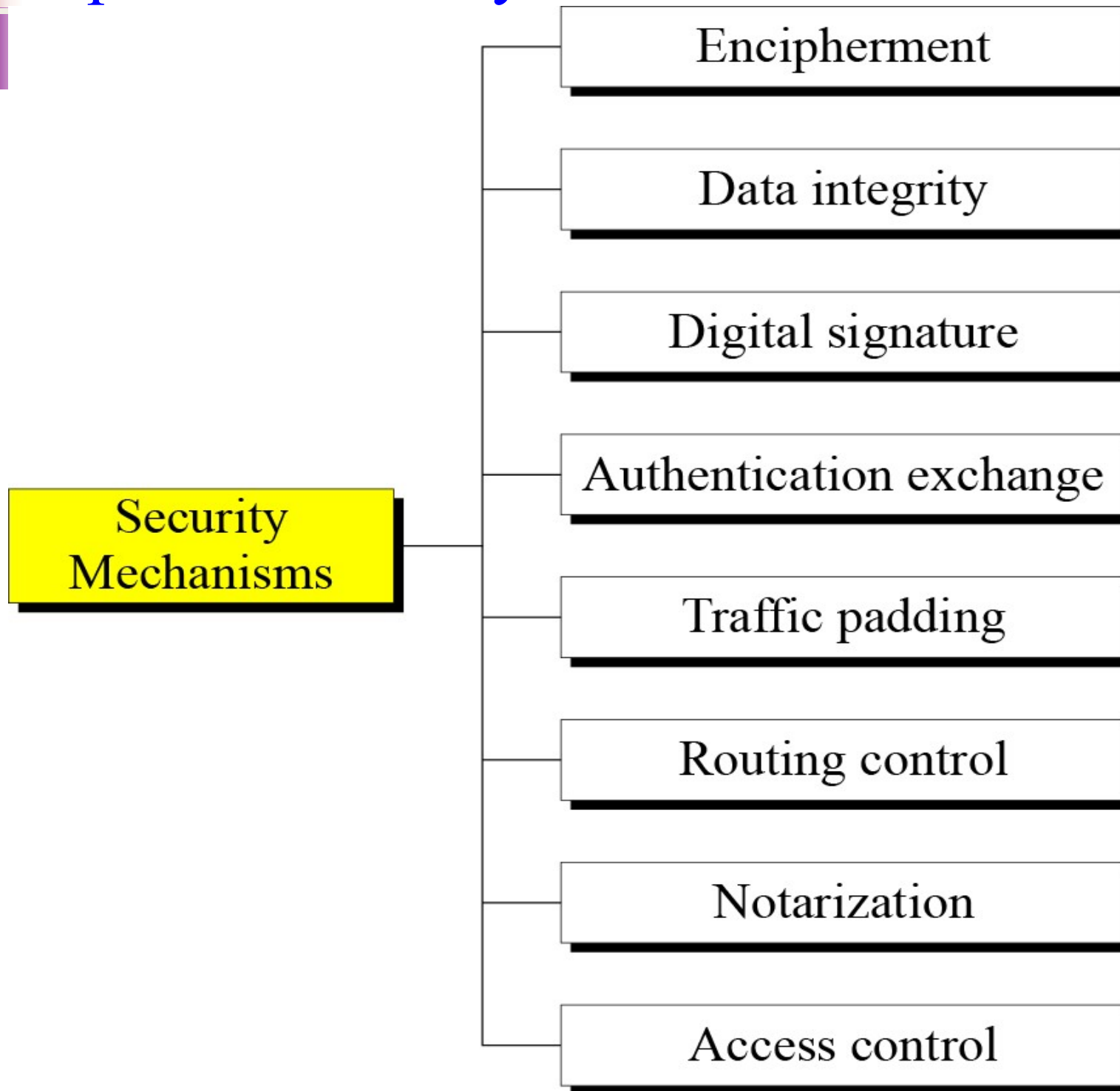
Security Mechanisms

Security Mechanism: A mechanism that is designed to detect, prevent, or recover from a security attack.





Specific Security Mechanisms

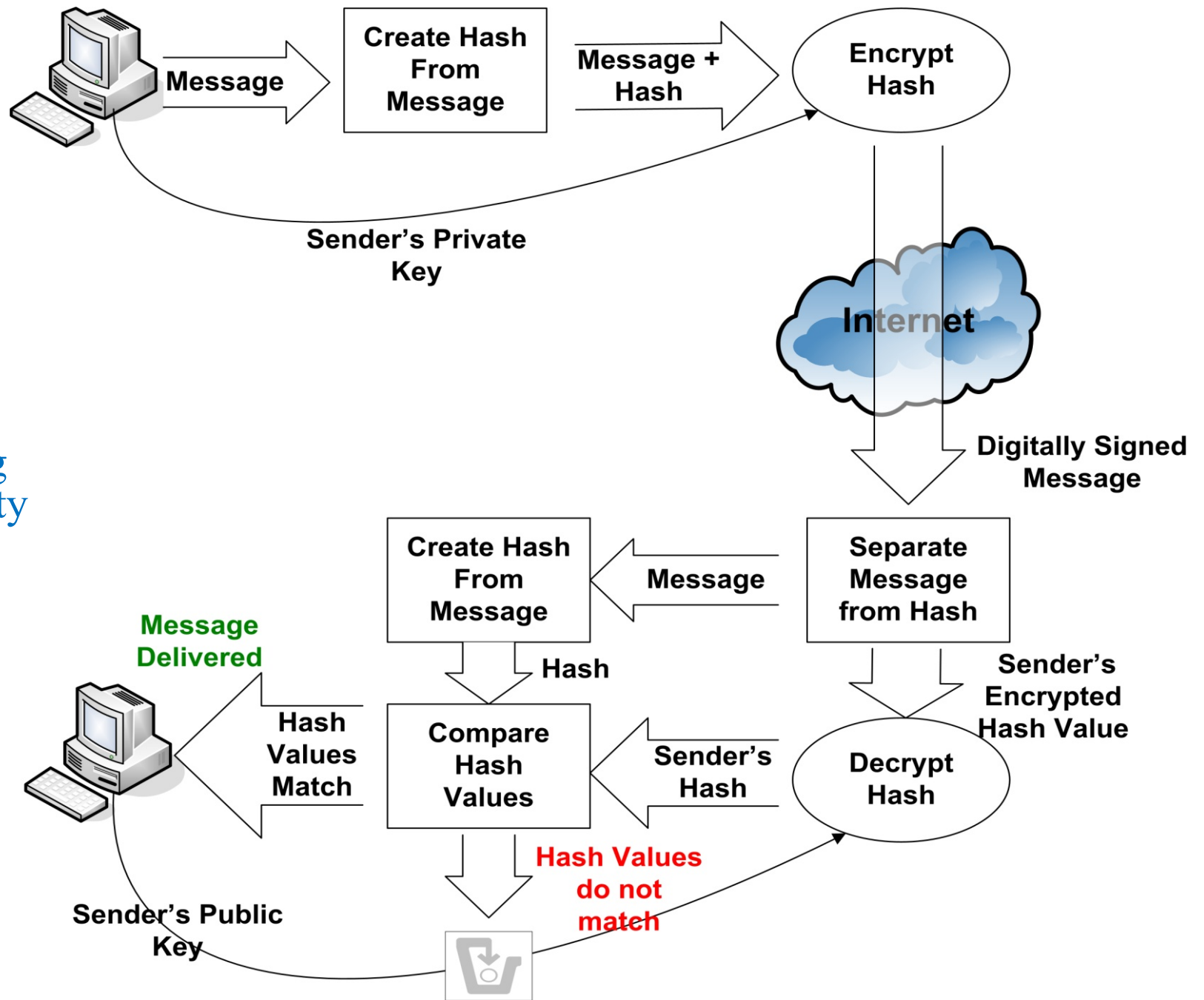


Mechanisms	Explanation
Encipherment	The use of mathematical algorithms to transform data into a form that is not readily intelligible. The transformation and subsequent recovery of the data depend on an algorithm and zero or more encryption keys.
Digital Signature	Data appended to, or a cryptographic transformation of, a data unit that allows a recipient of the data unit to prove the source and integrity of the data unit and protect against forgery (e.g., by the recipient). See
Access Control	Mechanisms that enforce access rights to resources.
Data Integrity	Mechanisms used to assure the integrity of a data unit or stream of data units.
Authentication Exchange	A mechanism intended to ensure the identity of an entity by means of information exchange
Traffic Padding	The insertion of bits into gaps in a data stream to frustrate traffic analysis attempts.
Routing Control	Enables selection of particular physically secure routes for certain data and allows routing changes, especially when a breach of security is suspected.
Notarization	The use of a trusted third party to assure certain properties of a data exchange.

Relationship between Security Services and Mechanisms

Mechanism								
Service	Encipherment	Digital Signature	Access Control	Data Integrity	Authentication Exchange	Traffic Padding	Routing Control	Notarization
Peer entity authentication	Y	Y			Y			
Data origin authentication	Y	Y						
Access control			Y					
Confidentiality	Y						Y	
Traffic flow confidentiality	Y					Y	Y	
Data integrity	Y	Y		Y				
Nonrepudiation		Y		Y				Y
Availability				Y	Y			18

Digital Signature

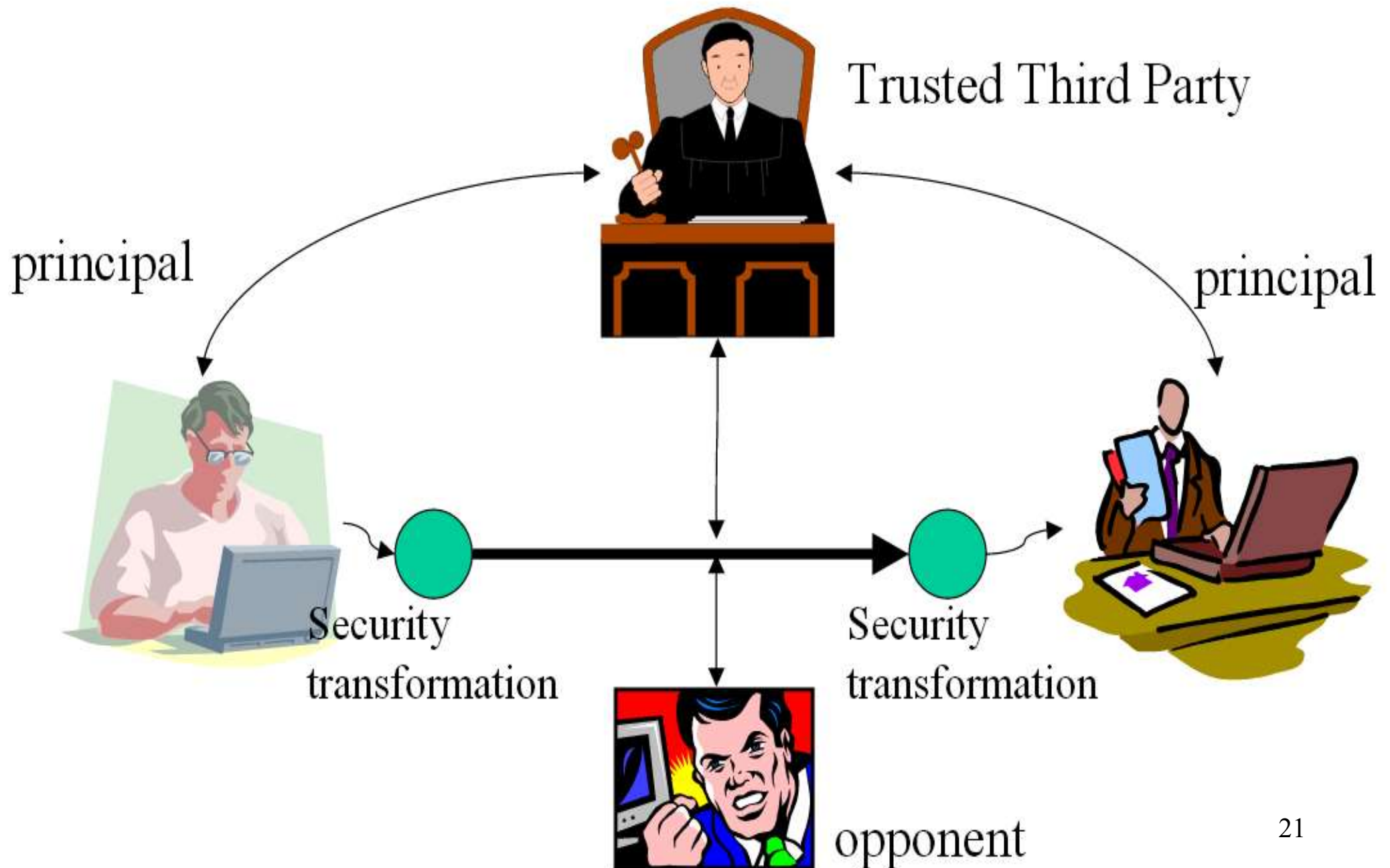


- **digital signature** – mathematical scheme for demonstrating the authenticity of a **digital** message or document.

Pervasive security mechanisms

Mechanisms	Explanation
Trusted Functionality	That which is perceived to be correct with respect to some criteria (e.g., as established by a security policy).
Security Label	The marking bound to a resource (which may be a data unit) that names or designates the security attributes of that resource.
Event Detection	Detection of security-relevant events.
Security Audit Trail	Data collected and potentially used to facilitate a security audit, which is an independent review and examination of system records and activities.
Security Recovery	Deals with requests from mechanisms, such as event handling and management functions, and takes recovery actions.

Network Security Model



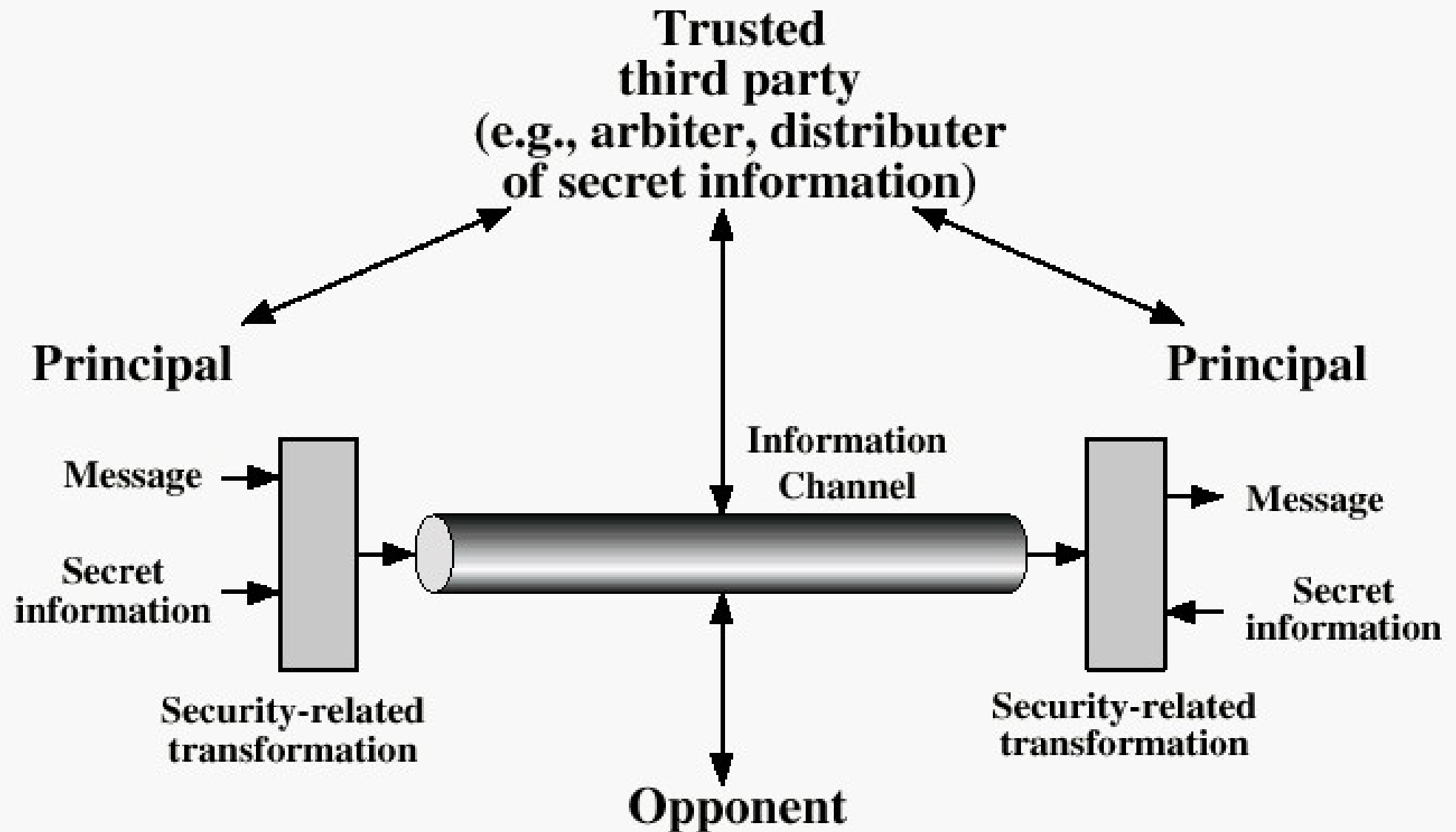


Figure 1.3 Model for Network Security

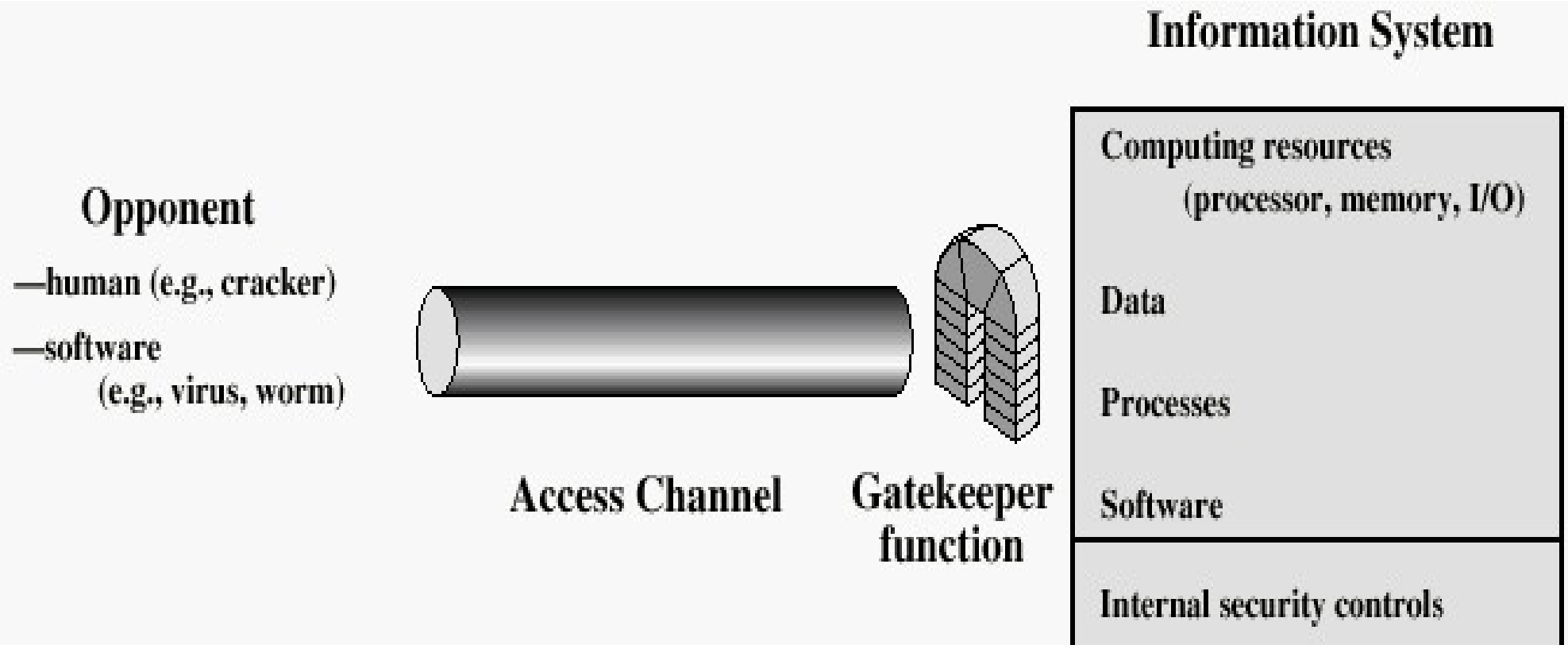


Figure 1.4 Network Access Security Model

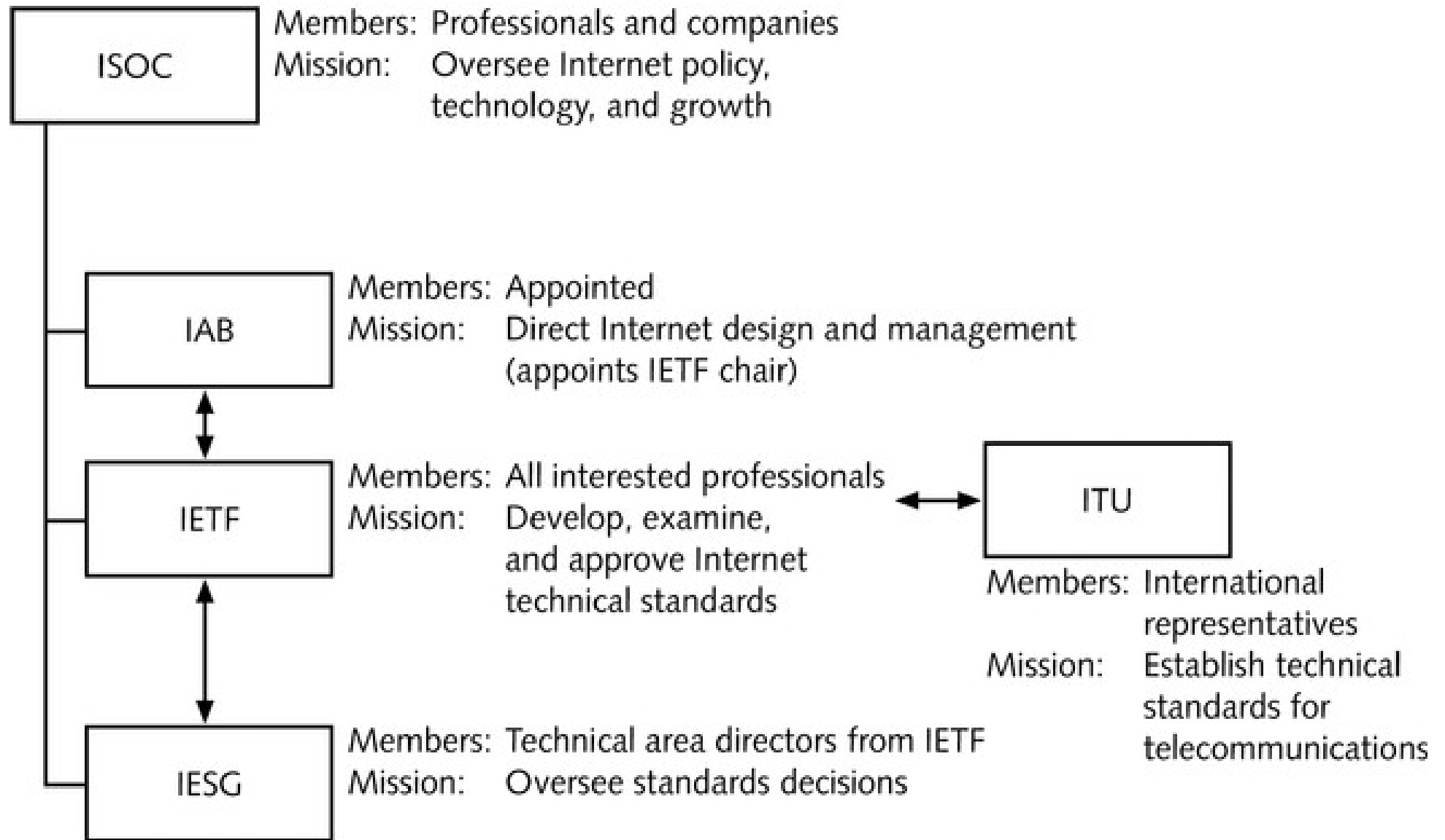
Methods of Defence

1. Encryption
2. Software Controls (access limitations in a data base, in operating system protect each user from other users)
3. Hardware Controls (smartcard)
4. Policies (frequent changes of passwords)
5. Physical Controls

Internet standards and RFCs

- The Internet society - coordinating committee for Internet design, engineering, mgmt.
 - Internet Architecture Board (IAB)
 - Internet Engineering Task Force (IETF)
 - Internet Engineering Steering Group (IESG)

Technical Specifications



Relationships between Internet technical standards authorities

Internet RFC Publication Process

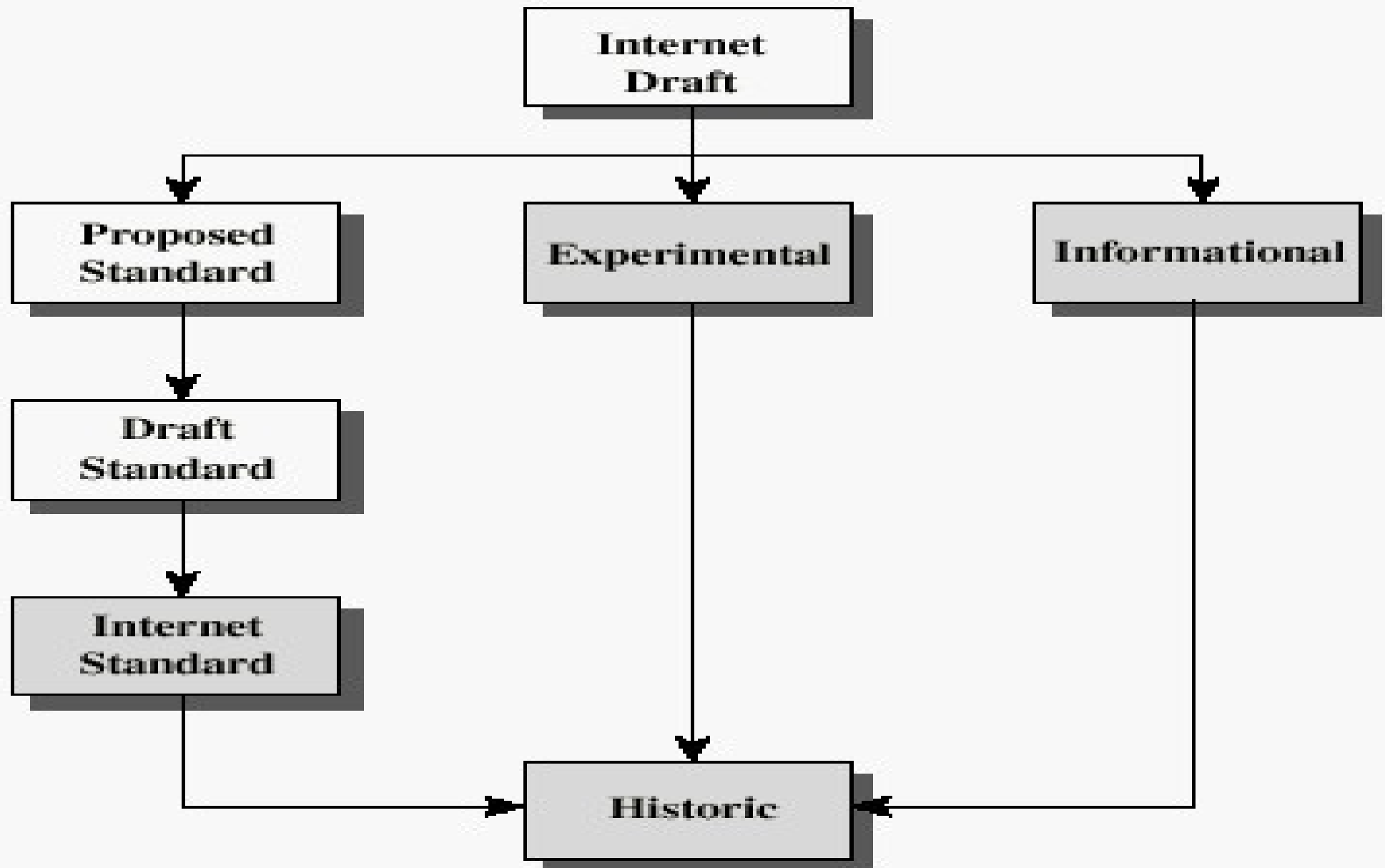


Figure 1.5 Internet RFC Publication Process

Recommended Reading

- Pfleeger, C. *Security in Computing*. Prentice Hall, 1997.
- Mel, H.X. Baker, D. *Cryptography Decrypted*. Addison Wesley, 2001.